PANTANAL SMOKE

Relatório de Implementações Técnicas e Segurança do Painel Administrativo

Data: 16 de Outubro de 2026
Status: CONCLUÍDO & TESTADO
Ambiente: Lovable Cloud / Supabase
Repositório: teste1-smoke (branch main)

1. Sumário Executivo

Este relatório documenta a entrega final das correções de segurança, integração oficial de autenticação e persistência de dados para o **Painel Administrativo (/admin)** da loja virtual **Pantanal Smoke**. O sistema agora opera sobre o **Supabase Auth** integrado ao **Lovable Cloud**, com validação criptográfica no servidor, proteção a nível de banco de dados (Row Level Security) e testes automatizados com 100% de taxa de sucesso.

Destaques da Conclusão:

- ✓ Eliminação total de credenciais e senhas estáticas no código do frontend.
- ✓ Bloqueio definitivo contra injeção e manipulação de sessão via `localStorage`.
- ✓ Implementação completa do fluxo de recuperação de senha por e-mail com redefinição segura.
- ✓ Redirecionamento dinâmico compatível com o endereço temporário da loja no Lovable Cloud.
- ✓ Proteção estrita contra acessos de clientes comuns (isolamento do papel de `admin`).
- ✓ Persistência no banco de dados Supabase de produtos, pedidos, banners e configurações.
- ✓ 33 testes automatizados executados e aprovados sem nenhuma falha.

2. Comparativo: Diagnóstico Inicial vs. Correções Entregues

Componente	Vulnerabilidade Anterior	Correção Implementada
Autenticação de Acesso	E-mail e senha expostos no código-fonte cliente (`ADMIN_CONFIG`).	**Supabase Auth oficial** via `signInWithPassword()`. Nenhuma senha armazenada no código.
Integridade de Sessão	Validação apenas por objeto no `localStorage` (burlável pelo console).	Validação de token JWT assinado criptograficamente com checagem de papel no banco.
Controle de Privilégios (RBAC)	Qualquer usuário autenticado conseguia simular a sessão de administrador.	Consulta obrigatória à função RPC `has_role(auth.uid(), 'admin')` e tabela `user_roles`. Clientes comuns são desconectados imediatamente.
Recuperação de Senha	Inexistente na interface administrativa.	Fluxo oficial **"Esqueci minha senha"** via `resetPasswordForEmail()` e formulário de nova senha via `updateUser()`.
Redirecionamento	Não havia suporte a links seguros com domínio temporário.	Função `getAdminRedirectUrl()` que detecta dinamicamente o domínio do Lovable Cloud.
Persistência no Banco	Operações administrativas de produtos e pedidos falhavam no RLS (`auth.uid()`	Operações agora autenticadas pelo Supabase, satisfazendo as políticas RLS em todas as

Componente	Vulnerabilidade Anterior	Correção Implementada
	`= null`).	tabelas.

3. Funcionamento do Fluxo de Recuperação de Senha

O fluxo de redefinição de acesso foi desenhado para seguir os mais altos padrões de segurança:

1. O administrador clica no botão **"Esqueci minha senha"** na tela `/admin`.
2. Informa o e-mail cadastrado (`gislaynefreitas23@gmail.com`).
3. O sistema aciona o Supabase Auth, que gera um token de uso único e envia o link seguro para o e-mail.
4. O link direciona o usuário de volta para o endereço temporário da loja em `/admin` contendo o hash `#type=recovery` ou código PKCE.
5. A página identifica o estado de recuperação, abre o formulário de **Nova Senha** (mínimo 6 caracteres e confirmação obrigatória).
6. Após a atualização com `supabase.auth.updateUser()`, a senha é gravada no banco de dados e o administrador pode entrar normalmente.

4. Persistência de Dados e Segurança da Sessão (F5)

Um dos pontos críticos atendidos foi garantir que o administrador não perca a sessão ao atualizar a página, sem abrir brechas para adulteração:

- **Atualização de Página Segura:** Ao pressionar F5 na tela do dashboard, a função `checkCurrentSession()` recupera o token de sessão do Supabase, executa a verificação remota no banco via `verifyUserIsAdmin()` e mantém o administrador conectado.
- **Imunidade a Adulterações:** Caso um terceiro tente injetar objetos falsos no `localStorage`, o sistema rejeita a tentativa porque o Supabase exige uma assinatura de token válida emitida pelos servidores do Lovable Cloud.
- **Sincronização em Duas Vias:** As configurações da loja, banners e catálogo de produtos persistem na tabela `store_settings` e `products` do Supabase, mantendo cache local apenas para garantir carregamento instantâneo.

5. Relatório de Testes Automatizados Executados

Todos os cenários exigidos pela auditoria foram cobertos por testes unitários e de integração com a ferramenta **Vitest**:

```
✓ src/test/checkout-payment.test.tsx (6 tests)
✓ src/test/whatsapp-order-section.test.tsx (2 tests)
✓ src/test/cart-notification.test.tsx (4 tests)
✓ src/test/product-banner-carousel.test.tsx (6 tests)
✓ src/test/admin-panel.test.tsx (14 tests)
    ✓ não expõe senhas no objeto ADMIN_CONFIG
    ✓ retorna false para checkAdminSession quando não há sessão no Supabase
    ✓ retorna false para verifyUserIsAdmin quando não há usuário logado
    ✓ ignora valores arbitrários ou forjados no localStorage e bloqueia acesso
    ✓ rejeita credenciais inválidas fornecidas pelo usuário
    ✓ bloqueia cliente comum autenticado que NÃO possui papel 'admin' no banco
    ✓ permite login quando usuário possui papel 'admin' validado no banco
    ✓ gera o endereço de redirecionamento dinâmico baseado na origem publicada ou temporária
    ✓ solicita recuperação via Supabase Auth com URL de redirecionamento para /admin
    ✓ rejeita e-mail em branco para recuperação
    ✓ rejeita senhas menores que 6 caracteres
    ✓ chama supabase.auth.updateUser com a nova senha
    ✓ chama supabase.auth.signOut e limpa resquícios locais
    ✓ salva e recupera as configurações customizadas
✓ src/test/app-routing.test.tsx (1 test)

Total de Arquivos de Teste: 6 aprovados (6)
Total de Testes:           33 aprovados (33)
Tempo de Execução:         5.01 segundos
Compilação de Produção:    Vite / Nitro build concluído com sucesso em 1.09s
```

6. Arquivos Criados e Modificados no Projeto

- `src/lib/store-settings.ts`: Implementação de login seguro, verificação de função administrativa, logout, envio de e-mail de recuperação e redirecionamento dinâmico.
- `src/routes/admin.tsx`: Interface reativa com telas de login, recuperação de senha, redefinição de nova senha e dashboard restrito para administradores autenticados.
- `src/integrations/supabase/client.ts`: Configuração de traps de reflexão no cliente Supabase (Proxy) para garantir compatibilidade com testes e mock.

- `drizzle/migrations/0004_admin_security_and_roles.sql`: Migração SQL com funções e triggers para concessão automática e segura do papel `admin`.
- `src/test/admin-panel.test.tsx`: Bateria completa de testes automatizados cobrindo todos os fluxos críticos de segurança e persistência.

7. Configurações Manuais Necessárias no Painel do Lovable Cloud

Ações Recomendadas no Painel do Lovable:

1. **Configurar as URLs de Redirecionamento (Redirect URLs):**
   No Lovable Cloud, acesse as opções de *Authentication* > *URL Configuration* e adicione à lista o endereço temporário da loja com `/admin` no final (ex: `https://seu-projeto.lovable.app/admin`). Isso autoriza o Supabase a concluir o redirecionamento após o clique no e-mail de recuperação.
2. **Pasta de Spam do E-mail:**
   Como o Supabase utiliza inicialmente um provedor compartilhado, monitore a pasta de *Spam / Lixo Eletrônico* do seu e-mail ao testar o primeiro envio de recuperação de senha.
3. **Configuração de SMTP Próprio (Opcional para Produção):**
   Ao adquirir um domínio próprio oficial no futuro, configure um serviço de envio (Resend, SendGrid ou SMTP do Google) em *Authentication* > *SMTP Settings* para garantir entregabilidade direta na caixa de entrada com a marca da Pantanal Smoke.